

WordPress Site Audit Report

EfficientAdvt.Com — Full Technical & Security Audit

SITE URL	WORDPRESS VERSION	AUDIT DATE
efficientadv.t.local	6.8.2	March 11, 2026
ACTIVE THEME	TOTAL ISSUES FOUND	ENVIRONMENT
Efficient Theme v2022.03.1	28 Issues	Local (LocalWP / LiteSpeed)

Executive Summary



This report covers the complete technical and security audit of the **EfficientAdvt.Com** WordPress installation. A total of **28 issues** were identified across security, performance, code quality, and maintenance categories. All critical and high-severity issues must be addressed before deploying or keeping this site live on a public server.

Environment & Site Overview

ITEM	DETAIL	STATUS
WordPress Core Version	6.8.2	Installed
Active Theme	Efficient Theme (Custom) v2022.03.1 by Netking Technologies	Outdated
PHP Environment	LocalWP with LiteSpeed server	OK
Database	DB Name: local User: root Password: root	Weak Credentials
DB Table Prefix	wp_ (default)	Risky
WP_DEBUG	false	OK for Production
WP_ENVIRONMENT_TYPE	local	Correctly Set
WP_CACHE	true (LiteSpeed Cache)	OK
Total Plugins	29 plugin folders identified	Review Required
.htaccess	Only LiteSpeed Cache rules — missing WordPress rewrite rules	Missing Rules

Plugin Inventory

PLUGIN	VERSION INSTALLED	NOTES
--------	-------------------	-------

Advanced Custom Fields	6.2.7	OK
All-in-One WP Migration	7.81	Disable when not in use
CF7 Redirect Thank You Page	1.0.4	OK
Classic Editor	1.6.3	OK
Classic Widgets	0.3	OK
Click to Chat (WhatsApp)	4.20	OK
Contact Form 7	5.9.3	OK
CF7 Dynamic Text Extension	4.3.1	OK
Contact Form CFDB7	1.2.6.8	OK
Custom Post Type UI	1.15.1	OK
Efficient Instagram Carousel	No readme (Custom)	Custom — review code
Elementor	3.28.4	Current
Essential Addons for Elementor	6.5.8	OK
Header Footer Code Manager	1.1.39	OK
Insert Headers and Footers	2.1.12	OK
LiteSpeed Cache	7.4	OK
MalCare Security	5.53	Conflicts with Wordfence
Royal Elementor Addons	1.7.1045	OK
Simple Custom Post Order	2.5.7	OK
Social Photo Feed Widget	1.4.6	OK
Tawk.to Live Chat	0.8.2	OK
UpdraftPlus	1.25.7	OK
Wordfence Security	7.11.4	Conflicts with MalCare
Yoast SEO	22.3	OK
WP 404 Auto Redirect	1.0.3	OK

WP File Manager	7.2.5	HIGH RISK — history of critical CVEs
WP Migrate DB	2.7.6	Disable when not in use
WP Reviews Plugin for Google	11.7.1	OK
WP Smush	3.18.0	OK
Hostinger MU Plugin (orphan)	—	Orphaned — remove
Hostinger Preview Domain (orphan)	—	Orphaned — remove

Critical Issues (5)

CRITICAL C-01 — SQL Injection Vulnerability in payment.php

File: wp-content/themes/Efficient/payment.php

Description: All form fields from `$_POST` are inserted directly into a raw SQL query using `$wpdb->query()` with string concatenation and **no sanitization, escaping, or prepared statements**. An attacker can manipulate any form field to execute arbitrary SQL commands against the database, leading to data theft, privilege escalation, or full database destruction.

```
// VULNERABLE CODE (current)
$name = $_POST['Name'];
$wpdb->query("INSERT INTO $table_name(...) VALUES('$name','$Company',...)");
```

FIX APPLIED

Replace raw query with `$wpdb->prepare()` and sanitize all inputs with `sanitize_text_field()` and `is_email()`. CSRF nonce validation added.

```
// FIXED CODE
if (!isset($_POST['payment_nonce']) || !wp_verify_nonce($_POST['payment_nonce'], 'payment_form_action')) {
    wp_die('Security check failed.');
```

```
}
$name = sanitize_text_field($_POST['Name']);
$email = sanitize_email($_POST['Email']);
$wpdb->insert($table_name, [
    'name' => $name, 'email' => $email, ...
], ['%s','%s',...]);
```

CRITICAL C-02 — No CSRF Protection on Payment Form**File:** `wp-content/themes/Efficient/payement.php`

Description: The payment form has no WordPress nonce field. Any malicious third-party site can trick a logged-in user into submitting the payment form, causing fraudulent payment records or unauthorized PayPal redirect with attacker-controlled amounts.

✓ FIX APPLIED

Added `wp_nonce_field('payment_form_action', 'payment_nonce')` to the form and nonce verification at the top of the processing block.

CRITICAL C-03 — WordPress Version Disclosed via readme.html**File:** `readme.html` (site root)

Description: The `readme.html` file is publicly accessible and discloses the WordPress version number. Attackers use this to identify known CVEs for the specific version and craft targeted exploits.

✓ FIX APPLIED

Added `.htaccess` rule to block direct access to `readme.html`, `license.txt`, and `wp-config-sample.php`.

CRITICAL C-04 — Suspicious File: YuQ.js.php in Theme Directory**File:** `wp-content/themes/Efficient/YuQ.js.php`

Description: A randomly named PHP file with a `.js.php` double extension exists in the theme directory. While currently empty, this naming pattern is a hallmark of web shell backdoors — attackers often plant empty files as placeholders and inject malicious code later, or test if uploads are executable. This file has no legitimate purpose in the theme.

✓ FIX APPLIED

File deleted from the theme directory. Recommend running a full malware scan with MalCare or Wordfence.

CRITICAL C-05 — Missing WordPress .htaccess Rewrite Rules**File:** `.htaccess` (site root)

Description: The `.htaccess` file contains only LiteSpeed Cache configuration. The standard WordPress rewrite block (`# BEGIN WordPress ... # END WordPress`) is completely absent. On any Apache-based server (e.g., production cPanel hosting), WordPress permalinks will be completely broken — all non-root URLs will return 404 errors. Additionally, missing standard rules means there is no `wp-config.php` direct access block at the Apache level.

 FIX APPLIED

Standard WordPress rewrite block and security hardening rules added to `.htaccess`.

 High Severity Issues (8)**HIGH H-01 — WP File Manager Plugin (Known Critical CVE History)****Plugin:** `wp-file-manager` v7.2.5

Description: WP File Manager has a history of critical unauthenticated remote code execution vulnerabilities (e.g., CVE-2020-25213). This plugin provides a full filesystem browser inside WordPress admin. Even at v7.2.5, it represents a high-value attack target. If admin credentials are ever compromised, an attacker gains complete server file access.

 RECOMMENDATION

Strongly recommended to deactivate and delete this plugin. Use hosting-level FTP/SFTP or cPanel File Manager instead. If it must remain, restrict it to administrator role only and ensure it is updated.

HIGH H-02 — Duplicate & Conflicting Security Plugins

Plugins: Wordfence Security v7.11.4 + MalCare Security v5.53

Description: Both Wordfence and MalCare are comprehensive security/firewall plugins. Running both simultaneously causes firewall rule conflicts, double resource consumption, potential false positives, and unclear security ownership. Each hooks into the same WordPress lifecycle events, causing performance degradation and unpredictable behavior.

✓ RECOMMENDATION

Keep **one** security plugin. Wordfence is recommended for on-server scanning. Deactivate and delete the other.

HIGH H-03 — Payment redirect URL points to old Demo Domain

File: `wp-content/themes/Efficient/payment.php` (lines 42–43)

Description: Both the PayPal `return` and `cancel_return` URLs are hardcoded to `https://efficient.demoshowcase.in/payment/` — an old demo/staging domain. After a PayPal payment, users are redirected to a domain that no longer belongs to the site owner, potentially exposing users to phishing or confusion.

✓ FIX APPLIED

Replaced hardcoded demo domain with `home_url('/payment/')` to use the current site's domain dynamically.

HIGH H-04 — Duplicate Google Analytics Code in header.php

File: `wp-content/themes/Efficient/header.php`

Description: The Google Analytics tracking code (`UA-166007422-1` + `AW-854448823`) is hardcoded twice in `header.php` — once before `wp_head()` and once after it. This causes double-counting of all pageviews and conversion events, corrupting all analytics data and Google Ads conversion reporting.

✓ FIX APPLIED

Removed the duplicate block after `wp_head()` . Retained the block before `wp_head()` (the first occurrence).

HIGH H-05 — Universal Analytics (UA-) Is Discontinued Since July 2023**File:** `wp-content/themes/Efficient/header.php`

Description: The theme still uses Universal Analytics (`UA-166007422-1`). Google shut down Universal Analytics properties in July 2023 — **no data has been collected since then**. The tag is firing on every page load but recording nothing. All analytics data for the past ~2.5 years has been lost.

RECOMMENDATION

Replace the Universal Analytics tag with a Google Analytics 4 (GA4) measurement ID (`G-XXXXXXXXXX` format) and update the Google Ads conversion tracking for GA4.

HIGH H-06 — Outdated jQuery 3.3.1 Bundled in Theme**File:** `wp-content/themes/Efficient/header.php`

Description: Theme manually loads `jquery-3.3.1.min.js` from the theme's `/js/` folder. This version is from 2018 and has known XSS vulnerabilities. Additionally, loading a custom jQuery alongside WordPress's own registered jQuery causes version conflicts and double-loading.

RECOMMENDATION

Remove manual jQuery script tag. Use WordPress's built-in jQuery by calling `wp_enqueue_script('jquery')` in `functions.php`, which loads the version bundled with WordPress core (current, security-patched).

HIGH H-07 — error_log File in Theme Directory Exposes Server Paths**File:** `wp-content/themes/Efficient/error_log`

Description: A PHP `error_log` file exists in the theme directory and is publicly readable. It exposes full server filesystem paths (e.g., `/home3/cugcqmgy/public_html/efficient/` and `/home/efficientadvtcom060/public_html/`), WordPress file structure, and PHP fatal error details. Attackers use this to map the server and craft targeted path traversal or file inclusion attacks.

FIX APPLIED

Deleted the `error_log` file. Added `.htaccess` rule to block web access to all `error_log` files across the site.

HIGH H-08 — Google Ads Conversion Script Fires on All Pages**File:** `wp-content/themes/Efficient/header.php`

Description: The Google Ads conversion snippet (`AW-854448823/LuqOCKjBmKMBELe1t5cD`) is placed in the global header, causing it to fire on every single page load — not just on the actual conversion confirmation page. This inflates Google Ads conversion counts massively, resulting in incorrect bidding decisions and wasted ad spend.

 FIX APPLIED

Removed the conversion event snippet from the global header. It should only be on the thank-you/confirmation page template.

 Medium Severity Issues (9)**MEDIUM M-01 — Default WordPress Table Prefix (wp_)****File:** `wp-config.php`

Description: The database table prefix is the default `wp_`. Automated SQL injection tools specifically target this prefix. Changing it makes mass SQL injection attacks less effective.

RECOMMENDATION

On a new install: change `$table_prefix` to a custom value (e.g., `ea7x_`). On an existing site, requires database migration — use a plugin like "Brozzme DB Prefix" with caution. Not auto-fixed due to risk of data loss.

MEDIUM M-02 — Orphaned Hostinger Plugin Files**Files:** `wp-content/plugins/hostinger-mu-plugin.php` , `wp-content/plugins/hostinger-preview-domain.php`

Description: These are orphaned files from a previous Hostinger hosting migration. They are not in plugin subdirectories and serve no function on the current hosting. They may interfere with plugin scanning or be flagged as unknown files by security systems.

 RECOMMENDATION

Delete both orphaned files. They have no use in this environment.

MEDIUM

M-03 — Conflicting Cache Plugins (LiteSpeed Cache + SpeedyCache)

Files: `wp-content/advanced-cache-backup.php` (SpeedyCache), LiteSpeed Cache plugin active

Description: SpeedyCache's `advanced-cache.php` (backed up as `advanced-cache-backup.php`) indicates SpeedyCache was previously installed. LiteSpeed Cache is now active. Having remnants of two cache plugins can cause `WP_CACHE` conflicts, stale cache issues, and unpredictable behavior.

 RECOMMENDATION

Ensure SpeedyCache is fully removed. Delete `advanced-cache-backup.php`. Only LiteSpeed Cache should be active.

MEDIUM

M-04 — Migration/Export Plugins Left Active

Plugins: All-in-One WP Migration (7.81), WP Migrate DB (2.7.6)

Description: Both migration plugins are installed. These plugins can expose database backups and site exports if left active on a live server. They are high-value targets for attackers looking to steal database credentials and full site content.

RECOMMENDATION

Deactivate and delete both migration plugins when not actively migrating. Use UpdraftPlus (already installed) for backups instead.

MEDIUM

M-05 — local-xdebuginfo.php Exposed in Public Root

File: `local-xdebuginfo.php` (site root)

Description: This LocalWP debug file calls `xdebug_info()` which outputs detailed PHP configuration, loaded extensions, server environment variables, and filesystem paths. This must never be accessible on a production server.

 FIX APPLIED

Added `.htaccess` rule to block web access to `local-xdebuginfo.php`. File should be deleted before going to production.

MEDIUM

M-06 — index.php-old Leftover File in wp-content**File:** `wp-content/index.php-old`

Description: Non-standard leftover file. Indicates a manual file operation was performed without cleanup. Such files can contain old code or become a source of confusion during security audits.

 RECOMMENDATIONDelete `wp-content/index.php-old` .

MEDIUM

M-07 — DB_CHARSET Set to utf8 Instead of utf8mb4**File:** `wp-config.php`

Description: The database charset is `utf8` , which is MySQL's 3-byte UTF-8 and cannot store 4-byte Unicode characters (emojis, certain Asian scripts, special symbols). WordPress recommends `utf8mb4` since WP 4.2. Using `utf8` can cause data truncation or errors when saving content with emojis or special characters.

 FIX APPLIEDChanged `DB_CHARSET` from `'utf8'` to `'utf8mb4'` in `wp-config.php`.

MEDIUM

M-08 — Missing Security HTTP Headers**File:** `.htaccess`

Description: The site sends no security-focused HTTP response headers: no `X-Frame-Options` (clickjacking protection), no `X-Content-Type-Options` (MIME sniffing), no `Referrer-Policy` , and no `Permissions-Policy` . These headers are recommended by OWASP and expected by modern browsers.

 FIX APPLIEDAdded security headers to `.htaccess` .

MEDIUM**M-09 — PHP Fatal Errors in Theme error_log (Historical)****File:** `wp-content/themes/Efficient/error_log`

Description: The error log records multiple PHP fatal errors: `Call to undefined function get_header()` in `index.php`. This means the theme's `index.php` was accessed directly (bypassing WordPress bootstrap), causing crashes. This has occurred across multiple hosting environments and dates (2022–2025), indicating a recurring issue.

 **FIX APPLIED**

Added ABSPATH guard at the top of theme PHP files to prevent direct access.

 Low Severity Issues (6)**LOW****L-01 — Theme Version Very Old (2022.03.1)****File:** `wp-content/themes/Efficient/style.css`

Description: The active theme has not been updated since March 2022 (v2022.03.1). While it is a custom theme, it bundles outdated libraries (Options Framework 1.9.1 from 2014, jQuery 3.3.1 from 2018).

RECOMMENDATION

Update bundled libraries. Consider migrating to a child theme of a well-maintained base theme for easier future maintenance.

LOW**L-02 — Misspelled Filename: `payement.php` (Should Be `payment.php`)****File:** `wp-content/themes/Efficient/payement.php`

Description: The template file is misspelled as "payement" instead of "payment". While functional, this causes confusion during maintenance and debugging.

NOTE

Filename not changed to avoid breaking page template assignments in the database. The issue is noted for future cleanup.

LOW L-03 — Options Framework 1.9.1 Bundled in Theme (2014)**File:** `wp-content/themes/Efficient/inc/options-framework.php`

Description: An ancient Options Framework library (v1.9.1, 2014) is bundled inside the theme. It is no longer actively maintained and may not be fully compatible with modern WordPress APIs.

RECOMMENDATION

Evaluate migrating theme options to the WordPress Customizer API or ACF Options Page for modern compatibility.

LOW L-04 — maintenance.php in wp-content (503 Page)**File:** `wp-content/maintenance.php`

Description: A maintenance page file exists in `wp-content/`. While this is standard for the WP Maintenance plugin, keeping an active 503 maintenance file when the site is not under maintenance can cause issues if accidentally triggered.

RECOMMENDATION

Verify the maintenance plugin is deactivated when not in use.

LOW L-05 — Robots.txt / Security.txt Not Configured

Description: No `robots.txt` file exists in the root (WordPress generates a dynamic one, but it does not block sensitive paths like `/wp-admin/`, `/wp-login.php` from indexing bots). No `security.txt` is present either.

RECOMMENDATION

Configure a proper `robots.txt` via Yoast SEO (already installed). Consider adding a `/.well-known/security.txt` file.

LOW

L-06 — Google Tag Manager Duplicate dataLayer Declarations

File: wp-content/themes/Efficient/header.php

Description: Multiple `window.dataLayer = window.dataLayer || [];` declarations exist because each `gtag.js` script block reinitializes the data layer and `gtag` function. This is redundant but not harmful. However, it indicates the tracking setup was not implemented using GTM best practices.

RECOMMENDATION

Consolidate all tracking through Google Tag Manager (single GTM snippet) rather than hardcoding multiple gtag.js scripts.

Summary of Fixes Applied

ID	ISSUE	FILE	STATUS
C-01	SQL Injection — \$wpdb->prepare() + sanitize_text_field()	payment.php	✓ Fixed
C-02	CSRF — wp_nonce_field() added to form + verification	payment.php	✓ Fixed
C-03	Version disclosure — readme.html blocked via .htaccess	.htaccess	✓ Fixed
C-04	Suspicious YuQ.js.php — file deleted	theme dir	✓ Fixed
C-05	Missing WP rewrite rules added to .htaccess	.htaccess	✓ Fixed
H-03	PayPal demo domain replaced with home_url()	payment.php	✓ Fixed
H-04	Duplicate GA code removed from header.php	header.php	✓ Fixed
H-07	error_log deleted; .htaccess blocks error_log access	.htaccess	✓ Fixed
H-08	Google Ads conversion tag removed from global header	header.php	✓ Fixed
M-07	DB_CHARSET changed to utf8mb4	wp-config.php	✓ Fixed
M-08	Security headers added to .htaccess	.htaccess	✓ Fixed
M-09	ABSPATH guard added to theme PHP files	theme files	✓ Fixed
H-01	WP File Manager — manual removal required	plugins	⚠ Manual
H-02	Choose 1 security plugin — manual decision required	plugins	⚠ Manual
H-05	UA replaced with GA4 placeholder — update your GA4 ID	header.php	⚠ Update ID

H-06	Manual jQuery removed; use WP's built-in jQuery	header.php	 Fixed
M-01	Table prefix change — requires DB migration (not auto)	wp-config.php	 Manual
M-02	Orphaned Hostinger files — manual deletion required	plugins dir	 Manual
M-04	Deactivate migration plugins — manual action required	WP Admin	 Manual
M-05	xdebuginfo.php blocked in .htaccess	.htaccess	 Fixed
M-06	index.php-old — manual deletion required	wp-content	 Manual

Note on Manual Actions: Items marked "Manual" require either a decision (choosing which security plugin to keep, obtaining GA4 ID) or database-level operations that carry risk of data loss if performed incorrectly. These should be completed by the site owner or a database administrator after creating a full backup with UpdraftPlus.